

An Introduction to Information Security & Privacy Through the Lens of Software Engineering

CSCE/SOFT 469/869

Fall 2025

Textbook

- Janca, Tanya. *Alice and Bob Learn Secure Coding*. Wiley, 2025.
 - ISBN numbers: 9781394171705 (paperback), 9781394171729 (ePDF), 9781394171712 (ePub).
- Plus, select “war stories” and *opinions* from my 40+ years in industry & the never-ending current security threats/incidents, e.g.,
 - Knuckleheaded designs/implementations/deployments
 - Bad software engineering decisions/practices
 - Bad security policies
 - Good security policies that aren’t executed/enforced
 - “Penny-wise, pound-foolish” economic/management decisions

A new approach this year

- The past 5 classes taught information security & privacy (S&P) basics to establish *context* before getting into secure software engineering (SSE).
 - Past students told us they didn't have much exposure/background to S&P, but over time this has gotten better with internships, "security incident-of-the-day awareness" etc.
- This class will bring in context as appropriate as we go through the textbook.
 - An archive of the 2024 lectures is available on Canvas.

Course content [1]

Interleaved with Professor Bagheri's classes

- Software is often the last line of defense against attacks.
 - And too often it fails, e.g., [New Chrome Zero-Day Actively Exploited; Google Issues Emergency Out-of-Band Patch | The Hacker News](#)
 - The high-severity flaw is being tracked as CVE-2025-5419 (CVSS score: 8.8), and has been flagged as an out-of-bounds read and write vulnerability in the V8 JavaScript and WebAssembly engine.
 - Software is never standalone/working in a vacuum.
- Defending against attacks requires [PPT](#) (People, Process and Technology), with software representing a *fraction* of technology and being inextricably bound with the rest of PPT.

Course content [2]

- Most of the SSE content presented in this class is about commercial-grade software/systems, but we'll take a quick tour of
 - High-assurance software/systems for safety-critical requirements (e.g., avionics, durable medical equipment, critical infrastructure, etc.), including
 - Operational Technology (OT), where security intersects with the physical world of sensors and actuators
- Software cannot handle all security threats, e.g.,
 - Physical systems
 - Hardware problems
 - Bad policies,
 - People!
 - ...

Know this, before starting:

*Individuals/organizations don't want security, they need it!
(And they resent it.)*

They care (but do they care *enough*?) about two things, fundamentally:

1. The continuity of their critical operations
2. Protecting their own and their stakeholders' sensitive/critical assets

Or put another way, staying out of the news and staying out of court! (Absent meaningful penalties.)

Security: A definition

Source: G.R. Blakley III et al

- Security isn't hardware, software, policies or procedures – it's a condition
 - Security *n.* 1. Freedom from risk or danger: safety. 2. Freedom from doubt, anxiety, or fear; confidence
- Security is never absolute
 - People and organizations always face risks
 - **Humans are terrible at *objectively* assessing risk**
 - Some risks can be eliminated, some can be reduced, and others just must be tolerated (after risk reduction)
- Bad things *will* happen, so *resilience* must be paired with prevention

CIA: three definitions you'll see/use a lot

Note that these definitions differ slightly from the textbook

- Confidentiality: Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.
 - Alt.: Only authorized entities can access/disclose information.
- Integrity: Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity.
 - Alt.: Only authorized entities can modify/delete information.
- Availability: Ensuring timely and reliable access to and use of information.
 - Alt.: Information/systems are available when needed.

Everything's a computer (software/firmware)...

...with a network connection!

- Examples: Cars, phones, toys, appliances, the electric grid, EV chargers
- [Bruce Schneier](#) coined the term “Internet+” as the Internet + Things + Us
- Fast, cheap, good: you can have any two – guess which choices current incentives drive
- Too many of the people building the Internet+ don't understand how to build and maintain secure and safe systems
 - The exception being safety-critical systems such as avionics and durable medical equipment
 - And even these can take multiple iterations (e.g., Boeing 737 MAX)
 - Cyberwar & ransomware are churning the “critical infrastructure” and other waters

2024 CWE Top 25 Most Dangerous Software Weaknesses | Mitre.org [1]

1. Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')
2. Out-of-bounds Write
3. Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
4. Cross-Site Request Forgery (CSRF)
5. Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')
6. Out-of-bounds Read
7. Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')
8. Use After Free
9. Missing Authorization
10. Unrestricted Upload of File with Dangerous Type
11. Improper Control of Generation of Code ('Code Injection')

2024 CWE Top 25 Most Dangerous Software Weaknesses | Mitre.org [2]

- | | |
|---|---|
| 12. Improper Input Validation | 17. Exposure of Sensitive Information to an Unauthorized Actor |
| 13. Improper Neutralization of Special Elements used in a Command ('Command Injection') | 18. Incorrect Authorization |
| 14. Improper Authentication | 19. Server-Side Request Forgery (SSRF) |
| 15. Improper Privilege Management | 20. Improper Restriction of Operations within the Bounds of a Memory Buffer |
| 16. Deserialization of Untrusted Data | 21. NULL Pointer Dereference |

2024 CWE Top 25 Most Dangerous Software Weaknesses | Mitre.org [3]

- 22. Use of Hard-coded Credentials
- 23. Integer Overflow or Wraparound
- 24. Uncontrolled Resource Consumption
- 25. Missing Authentication for Critical Function

Assets, vulnerabilities, exploits, threats, risk & responses

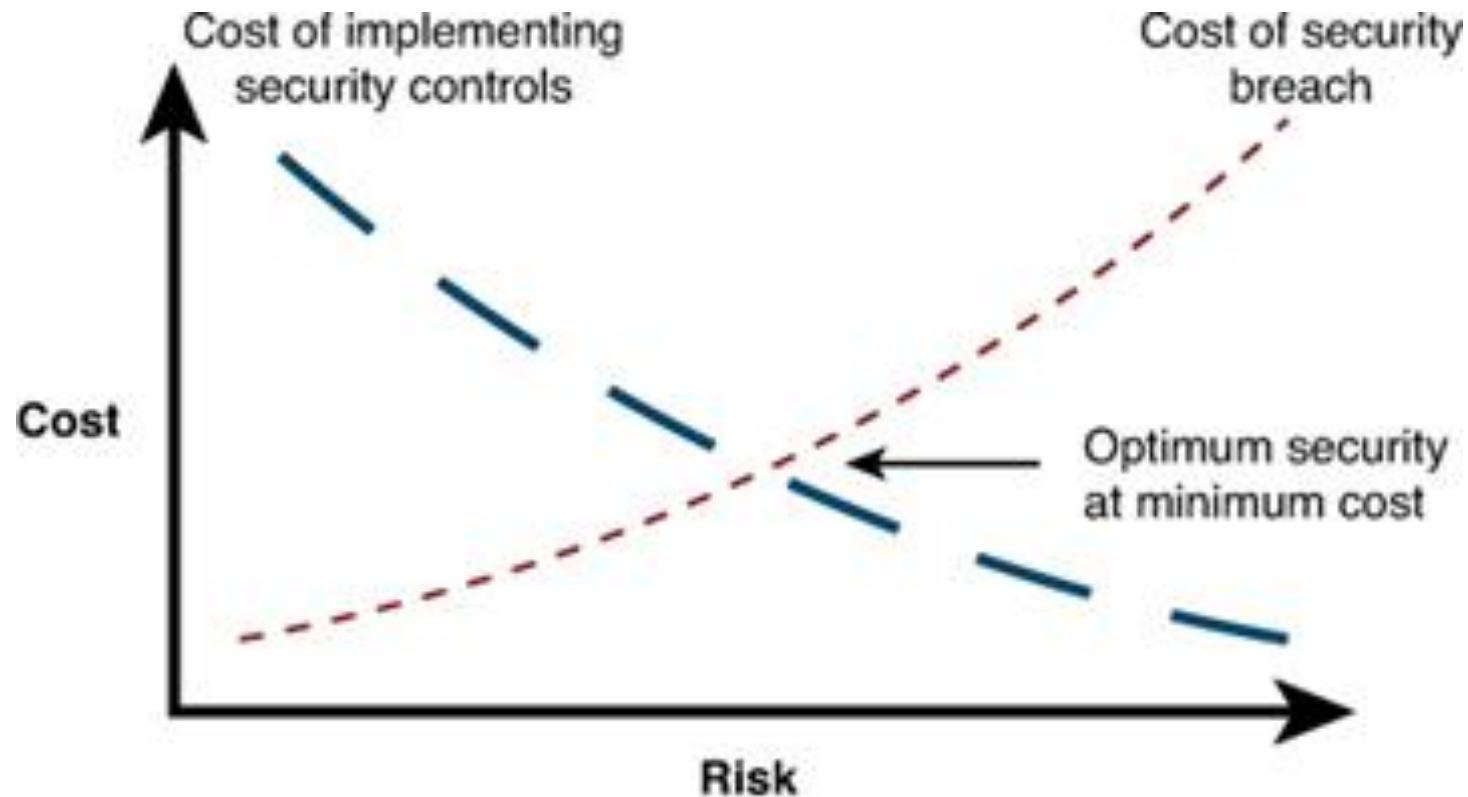
- **Assets** (people, property/things, information, reputation) is what we need to protect
- A **vulnerability** is a weakness/flaw in our security protections (many are dormant/undiscovered)
- An **exploit** is a method to take advantage of a vulnerability
- A **threat** is the probability of a successful use of an exploit
- **Risk** is the product of a threat times the consequence to the targeted asset(s)
- Organizations need to consider how best to **respond** to these risks.

Likelihood	Consequence				
	Minor	Moderate	Significant	Major	Severe
Almost Certain Is expected to occur	Low	Medium	High	Very High	Very High
Likely Will probably occur in most circumstances	Low	Medium	High	Very High	Very High
Possible Could occur at sometime	Low	Medium	Medium	High	Very High
Unlikely Event hasn't occurred but it could in some circumstances	Low	Low	Medium	Medium	High
Rare Exceptional circumstances only	Low	Low	Low	Medium	Medium

Source: Massey University

Don't overspend on mitigation

Image credit: https://ptgmedia.pearsoncmg.com/images/chap4_9781587142956/elementLinks/04fig04.jpg



Analysis of cost vs. risk
Cost of implementing security vs. cost of security breach

What assets need protection?

- **People**, e.g., patients (physically, and their Protected Health Information (PHI))
- **Property/things**, e.g., endpoints and critical infrastructure, including IoT+ (e.g., motor vehicles, insulin pumps, electrical substations, ...)
- **Information**
 - At rest (ever-growing, dispersed, uncategorized and *undiscovered*)
 - In motion
 - In use
 - Sensitive: Protected Health Information (PHI) and other Personally Identifiable Information (PII)
 - Jurisdiction/border concerns and considerations
- **Reputation**: Intangible/hard to quantify, but very easy to lose and hard to regain

Responding to risk

Risk management techniques after identifying/assessing/understanding (quantifying) risk

- **Avoid** things representing unacceptable risk
- **Transfer** (some) risk to third parties, e.g.,
 - Outsourcing payment card transactions
 - Business continuity/disaster recovery
 - Public cloud vendors for hosting workloads
 - Outsourced managed operations/services
- **Mitigate** (reduce) risk with technical and non-technical **controls** (*people, process & technology [PPT]*)
- **Accept/Manage the residual risk**
 - Optionally, purchase **insurance** for the residual risk
 - Although this often just encourages the bad actors, and less-than-best-efforts from asset owners

Why is security so difficult to achieve?

- Human nature
 - We're *terrible* at objective risk assessment
 - We seem to prefer to spend lots of (other people's) money on reaction instead of far less money on prevention
 - Self-regulation almost never works
 - People say they want security, but they go for fast & cheap (convenience>>security & privacy)
 - Organizations consistently underreport security incidents unless forced by laws & regulations (and usually fight new/tougher reporting requirements)
- Laws and regulations always lag technology/latest attacks
- Most current legal/regulatory fines are “chump change” to those required to pay
- Virtually *all* commercial software is *essentially immune to liability laws*
- Organizations view security as an expense, not an investment with a return
- Bad actors must only find *one* weak point to exploit
 - Defenders must be strong *everywhere*

Summing up

- Physical and cybersecurity is about risk management
- There's no such thing as perfect security
- Bad things *will* happen
- Once risk is identified, assessed and understood (quantified), organizations can decide which technical and non-technical mitigations to use in managing the residual risk
 - The emphasis vis-à-vis the residual risk is twofold:
 1. Minimize disruptions/downtime, maximize availability/speed of recovery (resilience)
 2. Minimize direct and indirect losses
- Compliance $\neq$ security; don't fall victim to the cult of compliance